Subdomain Takeover

& Link Hijacking

Introduction

Modern web applications request tons of resources spread across multiple domains. Sometimes, these resources are improperly managed which allow attackers to gain unauthorized access. Two of the popular attacks are Subdomain Takeover and Broken Link Hijacking.

What is Subdomain Takeover?

Subdomain Takeover is a vulnerability where an attacker takes control of a subdomain of a legitimate domain. This typically occurs when a subdomain's DNS record points to an external service, like a cloud platform or web host, that has been decommissioned or is no longer in use, allowing the attacker to acquire the abandoned service and consequently, the subdomain.

What is Broken Link Hijacking?

Broken Link Hijacking exploits hyperlinks on a website that point to a resource that no longer exists. An attacker can register the expired domain or claim the resource that the broken link points towards, thereby redirecting unsuspecting users to a malicious site under their control.

Impact

1. Phishing and Social Engineering Attack

Attackers can use a compromised subdomain to host convincing phishing pages disguised as a legitimate brand. This substantially increases the success rate of social engineering attacks, as users are more likely to trust a malicious page that appears to be part of the official website.

2. Malware Distribution

A successful takeover or hijacking allows attackers to distribute malware to a site's visitors. By injecting malicious code, users can be infected with spyware, ransomware and viruses which leads to widespread security incidents and damage to the victims.

3. Compromised User Trust and Loss of Reputation

When a website is used to host malicious content, the organization's reputation is severely damaged, leading to a significant loss of user trust. Visitors become hesitant to engage with the site, potentially causing long-term negative effects on the brand and business operations.

4. Data Leakage and Cross-Site Scripting (XSS)

In the case of subdomain takeover, attackers can exploit the vulnerability to bypass content restrictions or execute Cross-Site Scripting (XSS) attacks. This can lead to the theft of session cookies that work across all subdomains, potentially compromising user accounts and sensitive information.

Mitigations

1. Inventory Management and DNS Record Housekeeping

Maintain a thorough, up-to-date inventory of all domain names and subdomains, particularly those registered with third-party services. Critically, any DNS records (A, CNAME, or NS records) that point to external services that are no longer actively used must be promptly removed to prevent them from becoming dangling records.

2. Regular Security Assessments and PenTesting

Implement a schedule for regular security assessments, including penetration testing and vulnerability scanning. These proactive measures are essential to identify and remediate potential vulnerabilities, such as dangling DNS records, before an attacker can exploit them.

3. Consistent Audits for Broken Links

Regularly audit the entire website to identify and fix all broken links. Utilizing automated tools like Screaming Frog SEO Spider or OWASP ZAP can streamline this process, ensuring that dead links are either updated or removed to eliminate the opportunity for link hijacking.

4. Automated Monitoring and Safe Redirects

Set up automated monitoring systems to alert the security team when a linked third-party domain becomes unavailable or approaches its registration expiration date. Furthermore, implement safe redirects and robust error handling practices to prevent users from being exposed to malicious content if they click on an unresolved link

Practical

Using subliste3r under a kali container to scan for unused sub-domains.

Command: **sublist3r -d <website>**

```
~
● [kali] X❯ sublist3r -d chatgpt.org

                 ____        _      _ _     _   _____
                / ___| _   _| |__  | (_)___| |_|___ / _ __
                \___ \| | | | '_ \| | / __| __| |_ \| '__|
                 ___) | |_| | |_) | | \__ \ |_ ___) | |
                |____/ \__,_|_.__/|_|_|___/\__|____/|_|

                # Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for chatgpt.org
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] Error: Virustotal probably now is blocking our requests
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page
[-] Total Unique Subdomains Found: 1
www.chatgpt.org

~ took 2m40s
● [kali] X❯
```

Conclusion

Both Subdomain Takeover and Broken Link Hijacking stem from a common root cause: inadequate asset management and configuration oversight. The impact of these vulnerabilities range from data theft and malware to severe reputational harm. By adopting a proactive security posture that includes meticulous inventory management, regular security testing, and automated monitoring, organizations can effectively close these common attack vectors and safeguard their online platforms against exploitation.